

IT Hub Bug Bounty Audit Report

Action-by-action frontend audit for requisitions, inventory, service desk, maintenance, stock, and backoffice administration.

PROJECT
ISW Frontend

REPORT DATE
June 25, 2026

SCOPE
Frontend user actions and mutation flows

FINAL SCANNER RESULT
0 high, 3 medium, 0 low

Executive Summary

A bug bounty hunter agent and automated scanner were added to the repository, then the application was audited action by action. The review focused on user-triggered actions such as create, edit, delete, approve, decline, issue, acknowledge, assign, escalate, resolve, upload, filter, export, and authentication/session flows.

The major issue pattern found across the codebase was unsafe mutation execution: several requests built endpoint URLs from modal state or selected records, which could submit to `/undefined` endpoints or affect stale records. Other repeated patterns included missing error feedback, untrimmed form values, numeric fields submitted as strings, immediate destructive actions without guards, stale query invalidation, and debug output leaking workflow data.

Result: Build passes. The bug scanner now reports only three remaining medium findings, all from the local `.env` backend URL. The `.env` file was intentionally left untouched at the user's request.

Verification Summary

Check	Result	Notes
<code>npm run build</code>	PASS	Vite production build completes successfully. Existing large chunk warning remains informational.
<code>npm run bug:bounty</code>	PASS	Findings reduced to 3 medium, 0 high, 0 low.
<code>npm run lint</code>	KNOWN PRE-EXISTING ISSUES	Lint was not used as the success gate because the repository contains unrelated pre-existing lint issues.

Bug Bounty Agent

Artifact	Purpose
<code>.agents/bug-bounty-hunter.md</code>	Defines a repo-local bug bounty hunter agent profile for action-based audits.
<code>scripts/bug-bounty-scan.mjs</code>	Scans for common frontend risks such as hard-coded local APIs, insecure HTTP URLs, console output, unstable index keys, and direct window navigation.
<code>package.json</code>	Adds <code>npm run bug:bounty</code> for repeatable local scanning.

Fixed Findings By Action Area

1. Authentication and Session Handling

Risk	Fix Applied	Files
Logout cleared only part of the session, leaving refresh and reset flags behind.	Moved logout flows to a shared helper that clears <code>access_token</code> , <code>refresh_token</code> , <code>mustResetPassword</code> , and user data.	<code>src/lib/auth.ts</code> , <code>src/Components/NavBar.jsx</code> , <code>src/BackOffice/Navbar.jsx</code>
Failed refresh forced <code>window.location.href</code> , bypassing router state.	Replaced direct navigation with an <code>auth:session-expired</code> event handled by the app router.	<code>src/utils/config.js</code> , <code>src/App.jsx</code>
Auth flows and old comparison login printed sensitive workflow data to console.	Removed debug output and preserved toast-based user feedback.	<code>src/Components/Login.jsx</code> , <code>src/Components/LoginWithToken.jsx</code> , <code>src/Components/ForgotPassword.jsx</code> , <code>src/Components/ResetPassword.jsx</code> , <code>src/Components/LoginCompare.jsx</code>

2. User Requisitions and Approval Flow

Action	Risk	Fix Applied
Create/edit/cancel/follow up requisition	Missing profile hydration could crash creation; quantity and ID handling were inconsistent.	Added profile fallback, numeric quantity normalization, ID guards, row key fallback, and stronger query invalidation.

Action	Risk	Fix Applied
Department approve/decline	Approve/decline could hit <code>/undefined</code> ; decline reason accepted whitespace.	Added record ID guards, trimmed reasons, error toasts, disabled pending buttons, and queue invalidations.
ITD approve/decline	Same stale/missing ID and whitespace risks as department approval.	Applied the same guarded approve/decline handling and invalidation cleanup.

Files: `src/Components/Requisition.jsx` , `src/Components/DeptApproval.jsx` , `src/Components/ITDApapproval.jsx`

3. Stores, Stock, Issuance, and Acknowledgment

Action	Risk	Fix Applied
Issue item / mark pending stock	Quantity was capped by total stock instead of selected batch stock; endpoints could use missing IDs.	Added selected-batch quantity logic, request ID guards, trimmed remarks, reset state, and broad stock invalidations.
User acknowledgment	Mutation used selected component state, which could be stale or undefined.	Mutation now receives <code>stockIssuedId</code> explicitly and validates it before submission.
Stock returns, adjustments, thresholds	Return quantity was not capped, reject/accept could call undefined endpoints, zero adjustments were allowed.	Added quantity caps, ID guards, zero-delta prevention, trimmed reasons, and separate query invalidations.
Stock receiving	Fixed asset details were displayed but not enforced; edit save could close before related item update completed.	Validated fixed-asset details, normalized quantities, and waited for receipt and item update promises before closing.

Files: `src/Components/StoresOfficer.jsx` , `src/Components/Acknowledge.jsx` , `src/Components/Stock.jsx` , `src/Components/StoresPage.jsx`

4. Inventory Officer and Inventory Creation

Risk	Fix Applied	Files
Update inventory/device details depended on selected state inside mutation functions.	Mutation payloads now carry <code>inventoryId</code> explicitly, with guards before request.	<code>src/Components/Inv.Officer.jsx</code>

Risk	Fix Applied	Files
Quick-create inventory item could continue without a returned item ID.	Added response ID validation and trimmed quick-create fields including monitor details.	src/Components/Inv.Officer.jsx
Inventory create fields could submit missing item/user values or untrimmed procurement fields.	Added required guards, trimmed LPO/remarks, and improved query invalidation.	src/Components/Inv.Officer.jsx

5. Service Desk Requester, Queue, Details, Reports, and Knowledge Base

Action Area	Risk	Fix Applied
Reporter ticket create, confirm, rate, reopen, comment	Whitespace-only text, missing ID guards, and missing error handlers.	Added trimmed submit handlers, ID checks, error toasts, and modal reset behavior.
Support queue assign, accept, status, close, comment, escalate, maintenance, bulk	Inline handlers used stale <code>selectedTicket</code> state and could target undefined ticket IDs.	Moved actions to guarded handlers with explicit IDs and trimmed payloads.
Ticket detail support actions	Support mutations lacked consistent error feedback.	Added error toasts across accept, assign, status, escalate, comment, and maintenance creation.
Service desk SLA configuration	Edit modal closed before update succeeded and no error feedback was shown.	Close now happens on success only, with success and error toasts.
Knowledge base create/edit/publish/delete	Raw form values and missing record ID checks.	Added normalization, tag trimming, missing-ID guards, and selected article refresh after edit.

Files: `src/Components/ServiceDesk.jsx`, `src/Components/ServiceDeskQueue.jsx`, `src/Components/ServiceDeskTicketDetails.jsx`, `src/Components/ServiceDeskReport.jsx`, `src/Components/KnowledgeBase.jsx`

6. Preventive Maintenance and Maintenance Desk

Action	Risk	Fix Applied
Create/toggle/delete PM schedules	Frequency accepted weak numeric input; toggle/delete could use undefined IDs; delete fired immediately.	Added <code>InputNumber</code> , due-date guards, ID checks, trimmed notes, and delete confirmation.
Create maintenance job	Device search used manual query string and create could submit without a valid device.	Switched to API params, added selected device guards, and trimmed descriptions.
Resolve job, create requisition, assign technician	Mutations built URLs from modal state, risking stale or undefined ticket IDs.	Mutation payloads now carry <code>ticketId</code> explicitly, with validation and trimmed text fields.

Files: `src/Components/PMschedules.jsx`, `src/Components/Maintenance.jsx`

7. Backoffice Administration

Area	Risk	Fix Applied
Departments, units, suppliers, projects, requisition items	Create actions lacked error paths or accepted whitespace-only text; delete actions had no missing-ID guards.	Added submit normalizers, <code>onError</code> toasts, loading states, and delete ID checks.
Employees	Edit mutation depended on selected state; delete/reset password could use missing staff IDs; clipboard copy had no failure path.	Added explicit staff ID payloads, guards, trimmed identity fields, and clipboard error feedback.
Roles and permissions	Permission edit submitted <code>action</code> but mutation sent <code>actions</code> , risking dropped action updates.	Corrected payload shape, added role/permission guards, and normalized resource/role names.
Service desk categories, support profiles, skill tags	Update mutations used editing state inside mutation functions and could submit stale IDs.	Moved IDs into mutation payloads and added validation for category names, tag names, profile capacity, and skill tags.
IT item categories and catalog	Category update used stale editing state; item delete/edit lacked guards; submit data was not normalized.	Added explicit IDs, trimmed item/category data, validated required attributes, and guarded delete/update actions.

Files: `src/BackOffice/Department.jsx`, `src/BackOffice/Units.jsx`, `src/BackOffice/Supplier.jsx`, `src/BackOffice/Projects.jsx`, `src/BackOffice/RequisitionItems.jsx`, `src/BackOffice/Employees.jsx`, `src/BackOffice/Roles.jsx`,

```
src/BackOffice/ServiceDeskCategories.jsx , src/BackOffice/SupportProfiles.jsx ,
src/BackOffice/SkillTags.jsx , src/BackOffice/ItItemCategories.jsx ,
src/BackOffice/ItItems.jsx
```

8. Notifications, Reports, Uploads, and Legacy Debug Cleanup

Area	Risk	Fix Applied
Notification bell	Socket fallback hard-coded localhost and read actions silently failed.	Removed hard-coded fallback, required configured base URL, added ID guards and error toasts.
Reports	Debug logs leaked report data; TotalAssets used an invalid Vite env accessor; TotalDevices filter only logged values.	Removed logs, used API client params, added filter error feedback, and implemented client-side device filtering.
Shared upload component	Upload posted an empty file field instead of the selected file.	Stored selected file list and sent the selected originFileObj .
Legacy modal folder	Console output remained in unused or superseded modal files.	Removed modal console statements and replaced inline log callbacks with no-op or notification-safe handlers.

Files: src/Components/ui/NotificationBell.jsx , src/Components/InventoryReport.jsx ,
src/Components/MaintenanceReport.jsx , src/Components/TotalAssets.jsx ,
src/Components/TotalDevices.jsx , src/Components/upload/upload.component.jsx ,
src/Components/modals/**

Remaining Findings

Important: The user explicitly requested that .env remain untouched. The remaining scanner findings are documented here for deployment readiness only.

Severity	Location	Finding	Recommended Production Action
MEDIUM	.env:2	Commented local API URL http://localhost:7001 .	Keep local-only values out of production env files.
MEDIUM	.env:3	Active local-network API URL http://172.16.12.138:7001 .	Use the production HTTPS API endpoint before deployment.
MEDIUM	.env:3	HTTP protocol is used for API traffic in local configuration.	Use HTTPS in staging and production to protect tokens and user data in transit.

Conclusion

The frontend now has stronger guard rails around user actions, especially destructive actions and mutation flows that previously relied on mutable UI state. The remaining scanner findings are environment-specific and were left untouched by instruction.

Recommended next operational step: before production deployment, replace local HTTP API values with the official HTTPS backend endpoint in the deployment environment, not necessarily in this local development `.env`.